TECH BIZ SECURITY · SOC ANALYST INTERNSHIP · BATCH B-503

WEEK 3 · TASK 8

Cyber Kill Chain & MITRE ATT&CK

Submitted by	**Oscar ALIDJINOU**
Student ID	**TBS-INT-2026-2398**
Program	**SOC Analyst Internship (6 weeks)**
Company	**Tech Biz Security**
Date of submission	**01-11-2026**

01 Objective

When an alert arrives, a SOC analyst needs to place it in the story of an attack: where in the attack is this, and what is the attacker likely to do next? Two frameworks give that map. The Lockheed Martin Cyber Kill Chain describes an intrusion as seven stages, and MITRE ATT&CK catalogues the tactics and techniques attackers use in detail. This report explains both, studies one technique (T1110 Brute Force) in depth, and maps a complete attack onto both frameworks.

02 Proof of Completion

Room	Duration	Tasks	Status
TryHackMe: MITRE	60 min	8	Completed, room progress 100%
TryHackMe: Cyber Kill Chain	50 min	9	Completed, room progress 100%

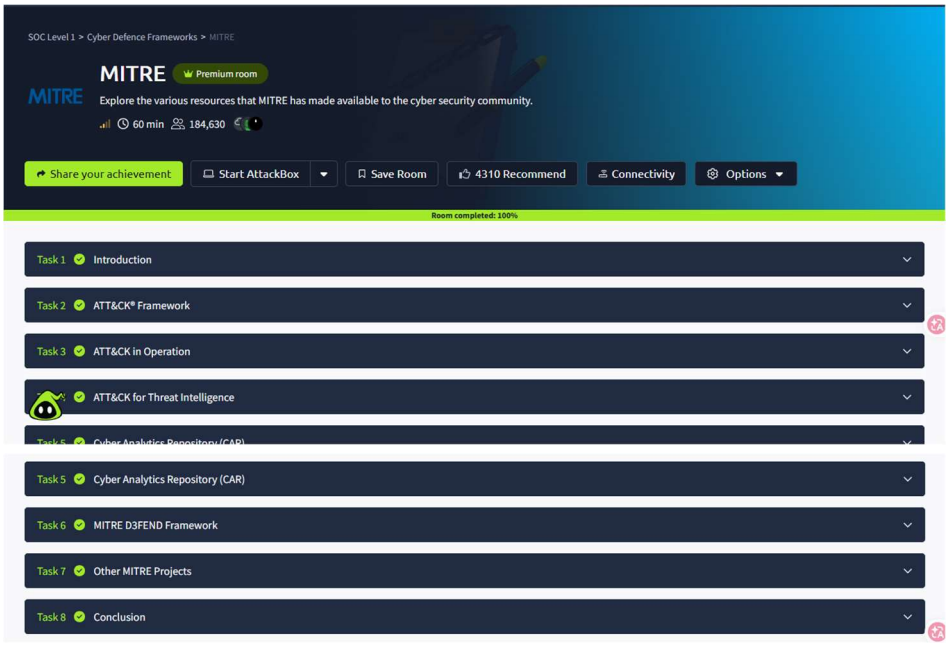


Figure 1. MITRE: all 8 tasks completed (100%).

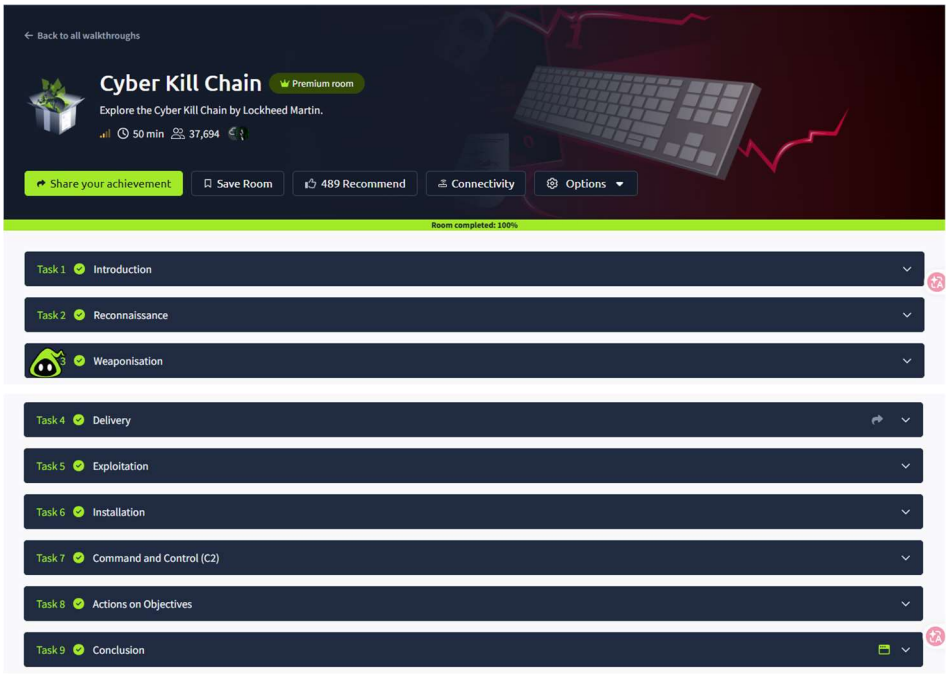


Figure 2. Cyber Kill Chain: all 9 tasks completed (100%).

03 The Cyber Kill Chain: Seven Stages

The Cyber Kill Chain, developed by Lockheed Martin, treats an intrusion as a chain of seven steps. The key idea is defensive: an attacker must complete every link, so stopping the chain at any stage stops the attack, and the earlier it is broken, the less damage is done.

#	Stage	What the attacker does	Examples
1	Reconnaissance	Gathers information about the target to find weaknesses and entry points.	Passive: searching public sources and social media. Active: scanning ports and services.
2	Weaponisation	Builds or adapts a payload to fit the weaknesses found.	A malicious document, a customised exploit, a trojanised file.
3	Delivery	Sends the payload to the target.	Phishing and spear-phishing emails, malicious links, file-sharing sites, malvertising, SMS, USB drives.
4	Exploitation	The payload runs and uses a weakness.	A software flaw, a weak or default password, a misconfiguration.
5	Installation	Installs a backdoor or malware to keep access (persistence).	A new account, a scheduled task or cron job, a startup entry.
6	Command and Control (C2)	Opens a hidden communication channel to control the machine.	Beaconing over HTTP or HTTPS, DNS tunnelling, domain generation algorithms.
7	Actions on Objectives	Carries out the real goal.	Data theft, ransomware, service disruption, spreading to other systems.

> **Blue team and red team**
> Defenders try to detect and block the attacker's actions at each stage. Red teamers and penetration testers follow the same stages to make their simulated attacks realistic, and to test whether the company's controls and team can spot them.

Sorting real actions into stages

The room ended with a drag-and-drop exercise: fourteen actions to place on the right stage of the chain. This is how each action fits.

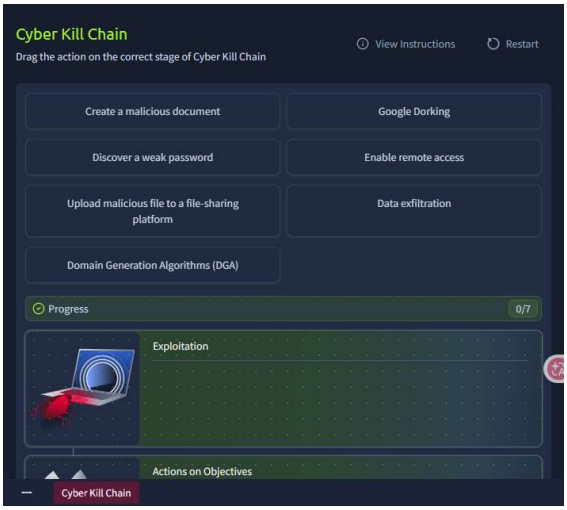


Figure 3. The Cyber Kill Chain exercise in the room.

Stage	Actions that belong to it
Reconnaissance	Google dorking (advanced search to find exposed data); a DNS query to learn about the target's hosts.
Weaponisation	Creating a malicious document; crafting a phishing email.
Delivery	Sending the phishing emails; uploading a malicious file to a file-sharing platform.
Exploitation	Discovering a weak password; logging in with default credentials.
Installation	Adding a malicious cron job in Linux; enabling remote access.
Command and Control	Using domain generation algorithms to find the C2 server; using SMTP for communication.
Actions on Objectives	Data exfiltration; manipulating an industrial control system (ICS).

04 MITRE ATT&CK

MITRE ATT&CK is a freely available knowledge base of how real attackers behave, built from observed attacks. It gives defenders and investigators one shared language. It is organised in four levels:

Level	Meaning	Example
Tactic	The attacker's goal, the "why".	Credential Access: getting usernames and passwords.
Technique	How the goal is achieved, the "how".	T1110 Brute Force.
Sub-technique	A specific variant of a technique.	T1110.003 Password Spraying.
Procedure	The exact way a real attacker or tool carried it out.	A named group guessing passwords with a particular tool.

4.1 The tactics columns

I opened the Enterprise matrix on the ATT&CK website. Each column is a tactic and each cell under it is a technique. Techniques with a small number beside them have sub-techniques that open when clicked.

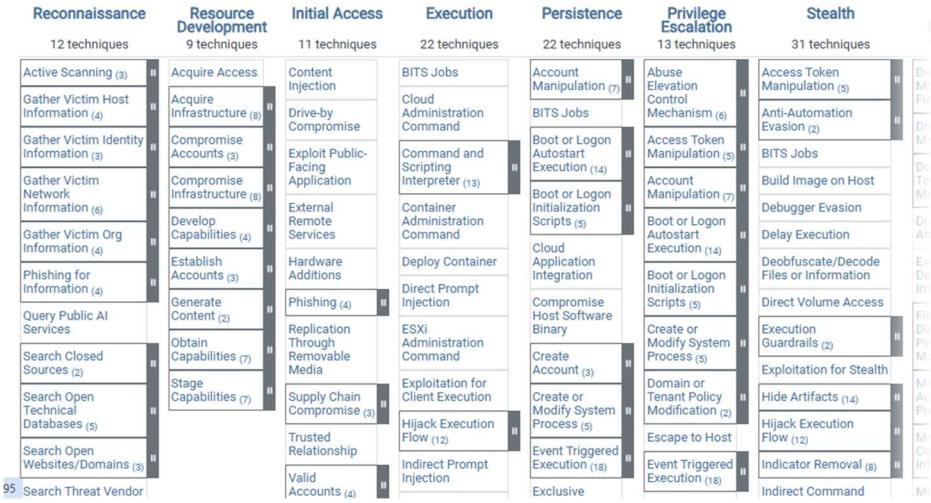


Figure 4. The Enterprise ATT&CK matrix: tactics as columns, techniques beneath.

> **A recent change**
> In ATT&CK version 19 (April 2026), the old Defense Evasion tactic was split into two: Stealth (TA0005), about hiding, and Defense Impairment (TA0112), about disabling defences. The Enterprise matrix now has 15 tactics, which is why my matrix shows both columns. Older reports and courses still say Defense Evasion.

Tactic	ID	The attacker's goal
Reconnaissance	TA0043	Gather information to plan the attack.
Resource Development	TA0042	Set up infrastructure, accounts and tools.
Initial Access	TA0001	Get into the network.
Execution	TA0002	Run malicious code.
Persistence	TA0003	Keep access across restarts and password changes.
Privilege Escalation	TA0004	Gain higher permissions.
Stealth	TA0005	Avoid being noticed (formerly part of Defense Evasion).
Defense Impairment	TA0112	Weaken or disable security tools and logging.
Credential Access	TA0006	Steal usernames, passwords and tokens.
Discovery	TA0007	Learn about the environment.
Lateral Movement	TA0008	Move between systems.
Collection	TA0009	Gather the data of interest.
Command and Control	TA0011	Communicate with compromised systems.
Exfiltration	TA0010	Steal the data out of the network.
Impact	TA0040	Disrupt, destroy or encrypt systems and data.

4.2 Who uses ATT&CK, and related MITRE projects

Who	How they use it
Threat intelligence teams	Map attacker behaviour to techniques so that reports are comparable and actionable.
SOC analysts	Link an alert to a tactic and technique to understand it and prioritise it.
Detection engineers	Map detection rules to techniques to see what is covered and what is missing.
Incident responders	Lay an incident timeline over the tactics to see the whole attack.
Red and purple teams	Build attack simulations that copy real groups and test the defences.

MITRE project	What it offers
CAR (Cyber Analytics Repository)	Tested detection analytics linked to ATT&CK, with pseudocode and examples for tools such as Splunk.
D3FEND	The defender's counterpart: a map of defensive techniques in seven groups: Model, Harden, Detect, Isolate, Deceive, Evict and Restore.
Adversary Emulation Library and Caldera	Step-by-step plans, and an automated tool, to simulate real threat groups in a controlled test.
AADAPT and ATLAS	Newer matrices in the same style, for digital asset payment systems and for threats against AI and machine learning.

05 Technique in Depth: T1110 Brute Force

T1110 Brute Force belongs to the Credential Access tactic. The attacker has no password, so they guess systematically until something works. The technique has four sub-techniques, which I could see when I opened it in the matrix.

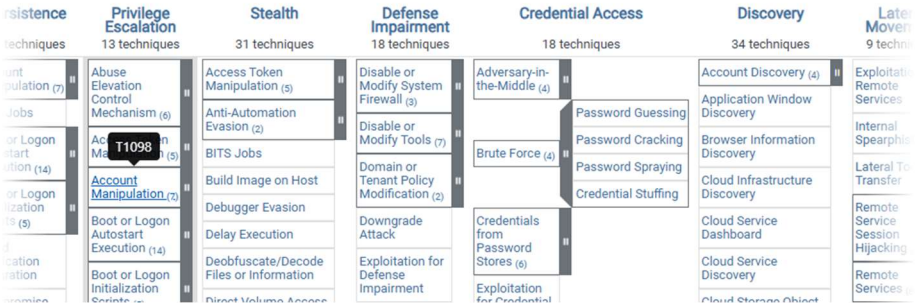


Figure 5. Credential Access in the matrix: Brute Force and its four sub-techniques.

ID	Sub-technique	How it works	Detection sign
T1110.001	Password Guessing	Tries likely passwords against one account, such as common or default ones.	Repeated failed logins for one account.
T1110.002	Password Cracking	Recovers a password from a stolen hash by testing guesses offline, as in the hash cracker I used.	Hard to see in logs, since it happens off the network; look for the earlier theft of hashes.
T1110.003	Password Spraying	Tries one or a few common passwords across many accounts, to avoid lockouts.	One source failing against many accounts; failures spread thinly across users.
T1110.004	Credential Stuffing	Reuses username and password pairs leaked from other services.	Logins with valid pairs from unusual locations; a rise in failed logins on a public service.

Detection

- **Windows:** a burst of Event ID 4625 (failed logon), followed by 4624 (success) is the most important pattern; 4740 records account lockouts.
- **Linux:** repeated "Failed password" lines in auth.log, then possibly an "Accepted" line.
- **Web and VPN logins:** many login requests from one IP, or one request type spread across many accounts.

I have seen these patterns in my own work: I created failed SSH logins in my lab and analysed a real 4625 event in Week 2, and I cracked a hash with a wordlist in Week 3.

Mitigations

ID	Mitigation	How it helps
M1032	Multi-factor authentication	A guessed password alone is not enough to log in.
M1036	Account use policies	Lockouts and rate limiting slow or stop guessing.
M1027	Password policies	Long, unique passwords resist guessing, spraying and cracking.
M1018	User account management	Removing default and unused accounts leaves fewer targets.

06 Mapping an Attack: Phishing to Ransomware

To bring the two frameworks together, I mapped a complete attack: a phishing email that leads to ransomware. The first columns follow the kill chain and the third column names the matching ATT&CK tactic and technique.

Kill chain stage	What happens	ATT&CK tactic and technique	Detect or break it
1 Reconnaissance	The attacker finds staff names and email formats from public sources.	Reconnaissance: T1589 Gather Victim Identity Information; T1593 Search Open Websites/Domains.	Hard to see. Watch for look-alike domains being registered for the company's name.
2 Weaponisation	A document with malicious code and a ransomware payload are prepared.	Resource Development: T1587 Develop Capabilities; T1588 Obtain Capabilities.	Threat intelligence about known malware kits.
3 Delivery	A phishing email with an attachment reaches an employee.	Initial Access: T1566.001 Spearphishing Attachment.	Email filtering, attachment sandboxing, user training.
4 Exploitation	The employee opens the file and the code runs.	Execution: T1204.002 User Execution: Malicious File.	Alert when Word or Excel starts PowerShell or cmd (process creation 4688).
5 Installation	A startup entry or scheduled task keeps the malware alive.	Persistence: T1547.001 Registry Run Keys / Startup Folder; T1053.005 Scheduled Task.	New Run key, new scheduled task (4698) or service (7045).
6 Command and Control	The malware contacts the attacker's server over HTTPS.	Command and Control: T1071.001 Web Protocols.	Regular outbound connections to a new domain; DNS and proxy logs.
7 Actions on Objectives	Backups are deleted and files are encrypted; a ransom note appears.	Impact: T1490 Inhibit System Recovery; T1486 Data Encrypted for Impact.	Shadow copy deletion, mass file renames, ransom notes.

What the mapping teaches me
Stopping the attack at delivery (a filtered email) or exploitation (a blocked macro) costs far less than recovering after stage 7. The kill chain tells me the order of events, and ATT&CK gives me the exact technique to detect at each step.

A second mapping: SSH brute force (T1110)

Kill chain stage	What happens in an SSH brute-force attack
Reconnaissance	A port scan finds SSH open on port 22 (T1595 Active Scanning).
Weaponisation	The attacker chooses a wordlist and a guessing tool.
Delivery	The login attempts are sent to the SSH service.
Exploitation	A guessed password works (T1110 Brute Force).
Installation	A new account or a cron job is added for persistence.
Command and Control	A reverse shell or tunnel gives remote control.
Actions on Objectives	Data theft, or installing a cryptocurrency miner.

07 Kill Chain vs ATT&CK

	Cyber Kill Chain	MITRE ATT&CK
Structure	Seven linear stages.	A matrix of 15 tactics (columns) with techniques and sub-techniques beneath.
Detail	High level; gives the overall story.	Very detailed; names exact behaviours.
Best used for	Explaining an attack and deciding where to break it.	Mapping alerts, measuring detection coverage, hunting and reporting.
Limit	Assumes a straight path and focuses on getting in; says little about what happens after.	Not ordered; an attacker may repeat or skip tactics.

How I will use them in a SOC

- **Identify** the behaviour in the alert.
- **Map** it to an ATT&CK technique and a kill chain stage.
- **Look before and after:** what usually comes earlier in the chain (how did they get in?) and what comes next (what will they do?).
- **Check coverage:** do I have detections for the neighbouring techniques?
- **Report** using the technique IDs so that colleagues and other teams read it the same way.

08 Reflection and Key Takeaways

- The Kill Chain explains the order of an attack, and ATT&CK explains the detail. Together they turn an isolated alert into a story.

- Attacks can be stopped at any stage, and early stages such as delivery are the cheapest to defend.
- The frameworks change: ATT&CK's split of Defense Evasion reminded me to check which version a report uses.
- T1110 links directly to my earlier lab work, which shows how a framework gives meaning to log patterns I already know.

Next step: map the alerts I meet in later tasks to ATT&CK techniques as I triage them.

09 References

- TryHackMe: MITRE and Cyber Kill Chain (rooms)
- MITRE ATT&CK, Enterprise matrix (attack.mitre.org)
- Lockheed Martin: The Cyber Kill Chain